Identity Exposure Lab

RED TEAM / Active Directory assessment with a report-ready evidence trail

What I set out to do

I built an isolated Active Directory practice environment to understand how everyday account and authentication weaknesses can turn into a serious domain compromise. The work covers basic discovery, two Kerberos-related weaknesses, and the risk created by exposed NTLM credentials. The final output is a penetration-test style report with clear impact and practical fixes.

Scope: a private VirtualBox Host-Only lab only. The sample domain is corp.local. No production systems or third-party networks are in scope.

How the project works

The workflow is straightforward: map the lab, confirm the relevant services, test the intentionally weak settings, record what happened, then explain the business impact and remediation. All testing should stay inside the isolated lab and be performed only with authorization.

Environment / scope

DC01 (192.168.56.10) is the domain controller, CLIENT01 (192.168.56.20) is the workstation, and Kali (192.168.56.30) is the testing machine. Keep the three virtual machines on a Host-Only network and take a clean snapshot before testing.

Evidence and findings

The source guide describes four test stages. The snippets below are evidence examples to help structure a report; capture the equivalent output from your own isolated lab before claiming the tests were run.

01 · Service discovery

Record the target, scan date, command used, and ports actually returned. A scan result should be attached as a text file as well as a screenshot.

```
Example command: nmap -sV -p 88,135,139,389,445,636,3268,3389 192.168.56.10 -oN dc_scan.txt
```

02 · Kerberos pre-authentication review

The guide's scenario uses a test account with pre-authentication disabled. Evidence should show the account configuration and the tool output without exposing any real credentials.

```
Expected evidence: a retrieved AS-REP response for the lab account; attach the raw output and
timestamp. Do not publish recovered passwords.
```

03 · Service ticket exposure

A service account with a Service Principal Name can be assessed for weak password exposure. Keep the ticket output in the private evidence folder and redact secrets in the public report.

```
Expected evidence: service-account/SPN listing and a lab-only ticket hash file; document whether
offline testing recovered the test password.
```

04 · Privileged access impact

The source guide demonstrates the potential impact of NTLM hash abuse. In a portfolio, show only a lab-owned proof of access and avoid publishing reusable hashes.

```
Expected evidence: terminal capture showing the lab identity and access level, host name, timestamp,
and corresponding finding ID.
```

What the evidence means

The key lesson is not that a particular tool was used. It is that weak account settings and over-privileged identities can create a path from limited access to broad domain control. The final report should connect each finding to the affected asset, evidence, severity, impact, and a fix that can be verified.

Recommended next steps

• Disable unnecessary services and restrict exposed ports on the domain controller.

• Require Kerberos pre-authentication unless an approved exception exists.

• Use long, unique service-account passwords and managed service accounts where possible.

• Reduce Domain Admin membership and review privileged logons.

• Enable Credential Guard where supported and reduce NTLM use through a planned compatibility review.

• Retest after remediation and attach the new output to the finding.

Finding summary

Finding	Risk	Why it matters	Priority fix
Kerberos pre-auth disabled	High	May allow offline password guessing without a normal login.	Enable pre-auth; review exceptions.
Weak service-account password	High	A service ticket may be cracked offline.	Use long random managed credentials.
Excessive domain privilege / NTLM exposure	Critical in the simulated scenario	Could allow high-impact access if privileged hashes are available.	Reduce admin rights; harden credential storage and NTLM.

Evidence integrity note

This portfolio document is based on the supplied project guide. The evidence snippets are illustrative lab examples or expected observations, not proof that a live system was tested by me. To present this as completed work, replace each example with a dated screenshot or exported log from your own lab, keep the original file, and record the tool version, host, timestamp, and test conditions.